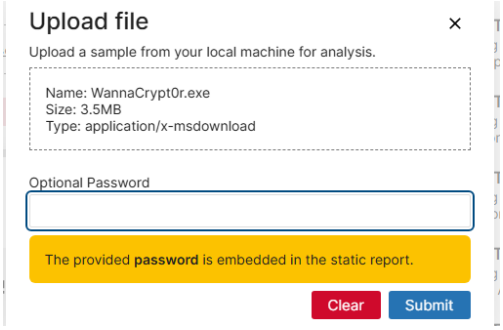
S9-L3

Report di analisi tecnica Malware

1. Executive Summary

L'analisi comportamentale del binario WannaCrypt0r.exe, condotta tramite la piattaforma **Triage**, ha rilevato una minaccia critica classificata come "Known bad" con un punteggio di pericolosità di 10/10. Il campione appartiene alla famiglia **Wannacry** ed esibisce caratteristiche proprie di un ransomware e di un worm. Le attività principali includono tecniche di evasione, persistenza, cifratura dei dati utente e la disabilitazione sistematica dei meccanismi di ripristino del sistema operativo.

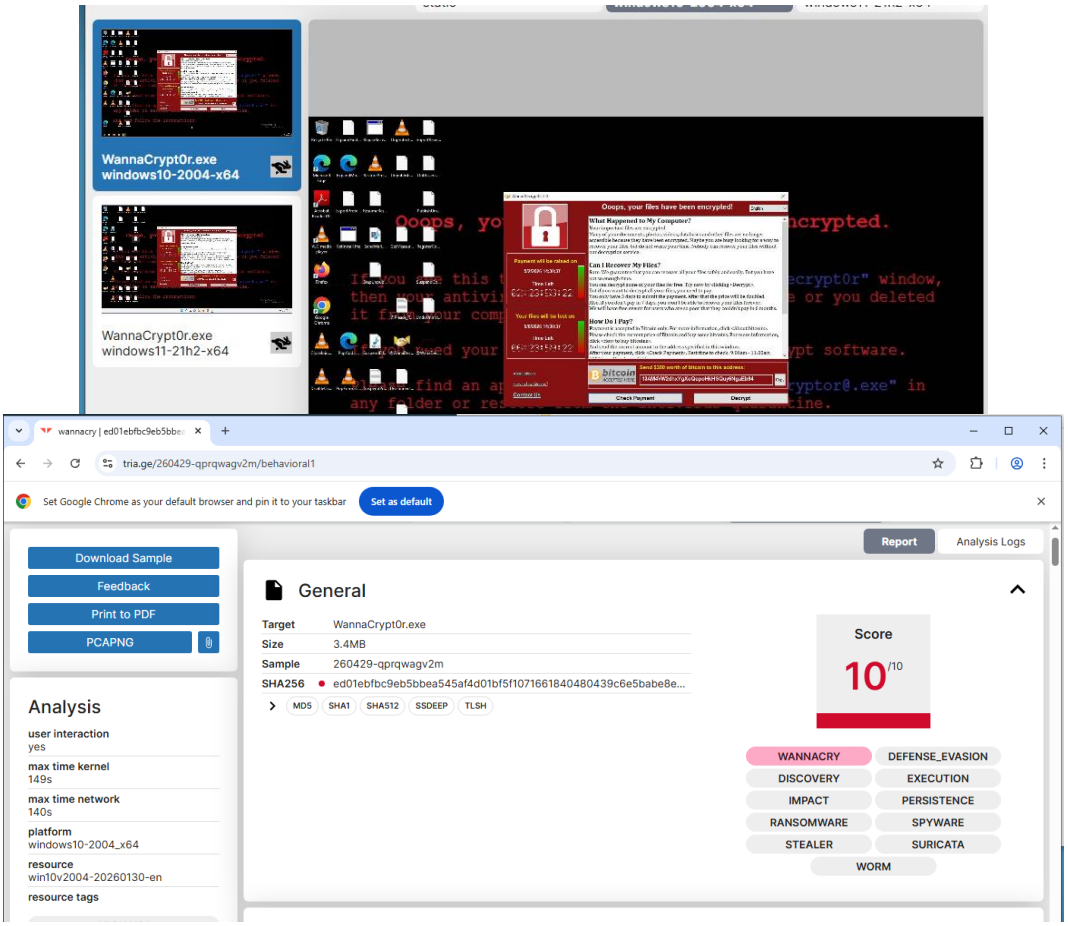


2. Identificazione del Campione

- **Nome File Originale:** WannaCrypt0r.exe
- **Dimensione:** 3.4MB
- **Hash SHA256:**

  ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa

- **Firma Digitale:** Eseguibile PE non firmato



3. Modifica del Sistema ed Evasione (Defense Evasion)

Il malware altera profondamente l'ambiente ospite per garantirsi privilegi elevati e nascondere le proprie tracce:

- **Permessi e Attributi:** Esegue icacls in modo silente per ottenere privilegi completi di accesso ("Everyone: F") e sfrutta attrib per nascondere file e directory di sistema (es. $RECYCLE tramite attrib +h +s).
- **Memory Injection:** Esegue operazioni di WriteProcessMemory all'interno di eseguibili di sistema legittimi (es. cmd.exe, attrib.exe, icacls.exe) e in moduli rilasciati dal malware stesso.
- **Manipolazione Privilegi:** Sfrutta WMIC.exe per alterare i token di sicurezza e forzare permessi critici, tra cui SeTakeOwnershipPrivilege, SeBackupPrivilege e SeRestorePrivilege.

4. Persistenza e Impatto (Ransomware Activity)

L'obiettivo centrale della minaccia è cifrare i dati e inibire qualsiasi tentativo di ripristino per forzare il pagamento:

- **Persistenza:** Aggiunge una chiave di registro Run (es. yvhjnjlpgm508 o mbvkvcmq257) configurata per eseguire automaticamente il componente tasksche.exe a ogni avvio della macchina.
- **Distruzione Backup (Inhibit System Recovery):** Per neutralizzare il recupero dei file, il malware esegue una catena di comandi silenti per rimuovere le Shadow Copies (vssadmin delete shadows /all /quiet e wmic shadowcopy delete) e disabilita il ripristino nativo di Windows modificando il bcdedit.
- **Defacement e Note di Riscatto:** Modifica la chiave di registro del wallpaper per mostrare un messaggio di allerta (@) e popola le directory con innumerevoli file con estensione .wnry contenenti le istruzioni di pagamento tradotte in svariate lingue.

5. Attività di Rete (Command and Control)

WannaCry stabilisce comunicazioni verso server remoti avvalendosi di tecnologie di anonimato:

- **Infrastruttura Tor:** Rilascia all'interno di una cartella temporanea i binari di Tor (tor.exe) accompagnati da librerie SSL/crittografiche come libeay32.dll e ssleay32.dll.
- **Traffico Esterno:** Instanzia connessioni in loopback sulla porta 9050 (usata dai proxy Tor). Sono state rilevate comunicazioni TCP in uscita verso indirizzi IP localizzati in Francia, USA, Germania, Paesi Bassi e Canada , generando allerte Suricata specifiche per pattern di certificati X.509 riconducibili a nodi Tor.

6. Conclusione

L'analisi tecnica conferma inequivocabilmente che il campione WannaCrypt0r.exe è un malware ad alto potenziale distruttivo appartenente alla famiglia **WannaCry**. Le routine di esecuzione mostrano un attacco su più fronti: l'inibizione aggressiva e immediata dei meccanismi di backup integrati (Shadow Copies e recovery boot) , l'assunzione totale dei privilegi sui file locali , e la conseguente richiesta di estorsione veicolata tramite la rete anonima Tor. Data la sua natura di "worm" – e dunque la sua spiccata capacità di propagazione automatica in rete (tipicamente tramite l'exploit SMB EternalBlue) – si raccomanda l'assoluto divieto di esecuzione di questo file al di fuori dell'ambiente sandbox isolato fornito per la consegna dell'esercizio, al fine di evitare la compromissione irreversibile della macchina virtuale FlareVM e dell'infrastruttura di rete circostante.